



西安电子科技大学
XIDIAN UNIVERSITY

现代密码学

MODERN CRYPTOGRAPHY

陈晓峰

网络与信息安全学院

Email: xfchen@xidian.edu.cn

Homepage: <http://web.xidian.edu.cn/xfchen>



第三讲 公钥加密技术

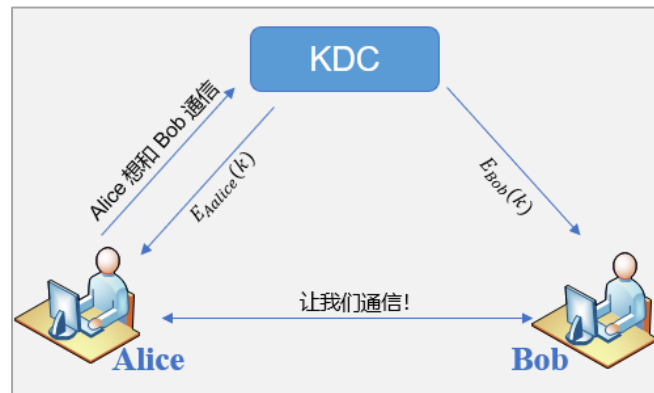
1. 概述
2. 陷门单向函数
3. 背包密码体制
4. RSA 加密
5. Rabin 加密
6. ElGamal 加密
7. Paillier 加密
8. 安全形式化定义
9. 混合加密



1.1 为什么需要公钥密码体制

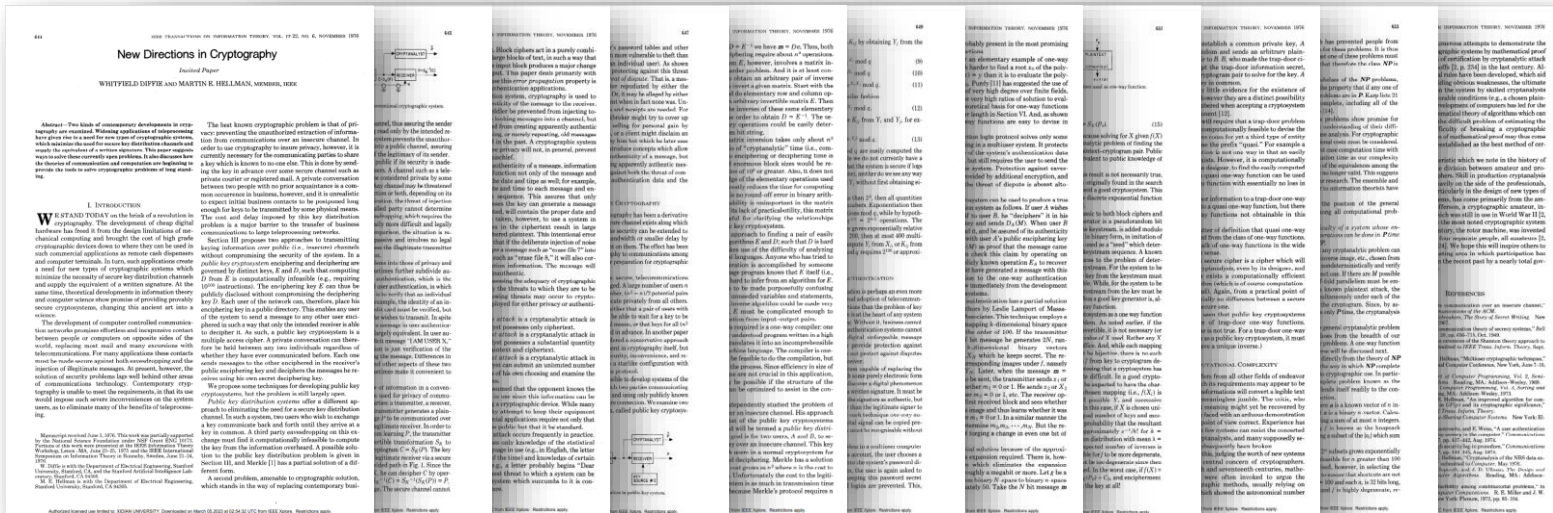
在私钥密码学中，密钥的产生通常使用安全可靠的方法进行协商，或者借助于一个可信的密钥分配中心。前者往往通过面对面协商或使用可信的信使来完成，这种方法成本高且完全依赖于信使的可靠性。后者则完全依赖于密钥分配中心的可靠性。因此，安全密钥管理是私钥密码学的核心问题，尤其是在大规模的网络保密通信中 (**估计密钥的数量级!**)。

使用公钥密码学，用户可以安全地在公开信道上进行通信，而不必事先商定共享密钥，也不需要借助可信密钥分配中心。





Whitfield Diffie 和 Martin Hellman 于 1976 年发表了 “New Directions in Cryptography” 一文。这篇划时代的文章奠定了公钥密码系统的基础。同时 Merkle 也独立提出了这一体制。



公钥密码体制不仅可用于保密通信，也可用于数字签名。这一体制的出现密码学史上是划时代的事件，它为解决计算机信息网中的安全提供了新的理论和技术基础。



- 1874 年, William Stanley Jevons 的书中描述了单向函数与密码学的关系, 并详细讨论了在 RSA 系统中用于构建陷门函数的整数分解问题。
- 1970 年代早期, 英国 GCHQ 部门的 Ellis, Cocks 和 Williamson 发明了第一个公钥密码算法, 即后来所谓的 “Diffie-Hellman 密钥交换” 和 RSA 的一个特例。然而, 该算法直到 1997 年才对外公布。



James H . Ellis



Clifford Cocks



Malcolm Williamson



- 1976 年，Whitfield Diffie 和 Martin Hellman 受到 Ralph Merkle 在公开密钥分发上的启发，提出了一种公开密钥协商方法，即“**Diffie-Hellman 密钥交换**”。这是第一个不需要事先共享秘密就可以在未受保护的信道上建立共享密钥的实用方法。Ralph Merkle 的公开密钥协商技术被称为**Merkle 谜题**，于 1978 年出版。



Whitfield Diffie



Martin Hellman



Ralphe Merkle



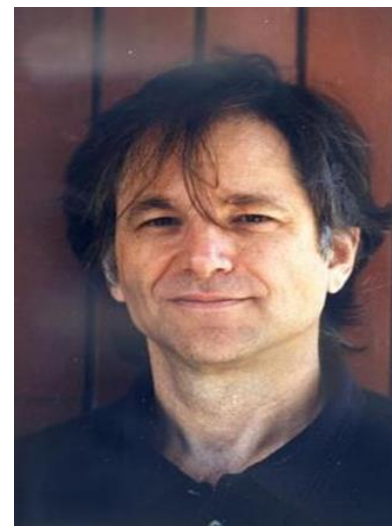
- 1977 年，MIT 的 Rivest , Shamir 和 Adleman 重新发现了 Cocks 方法的推广。该工作在 1978 年发表，后被称为 **RSA 算法**。该算法不仅可用于公钥加密，也可以用于公钥数字签名。它的安全性依赖于大整数分解问题的困难性，而这个问题目前还没有一个已知高效（即实用中快速）的解决方法。



Ronald Rivest



Adi Shamir



Leonard Adleman



1.2 第一个公钥密码协议: Diffie-Hellman 密钥交换协议

输入: (p, g) , p 是素数, g 是 F_p^* 的生成元



选择 x



选择 y

$$A = g^x \bmod p$$

计算 $K = B^x \bmod p$

$$B = g^y \bmod p$$

计算 $K = A^y \bmod p$

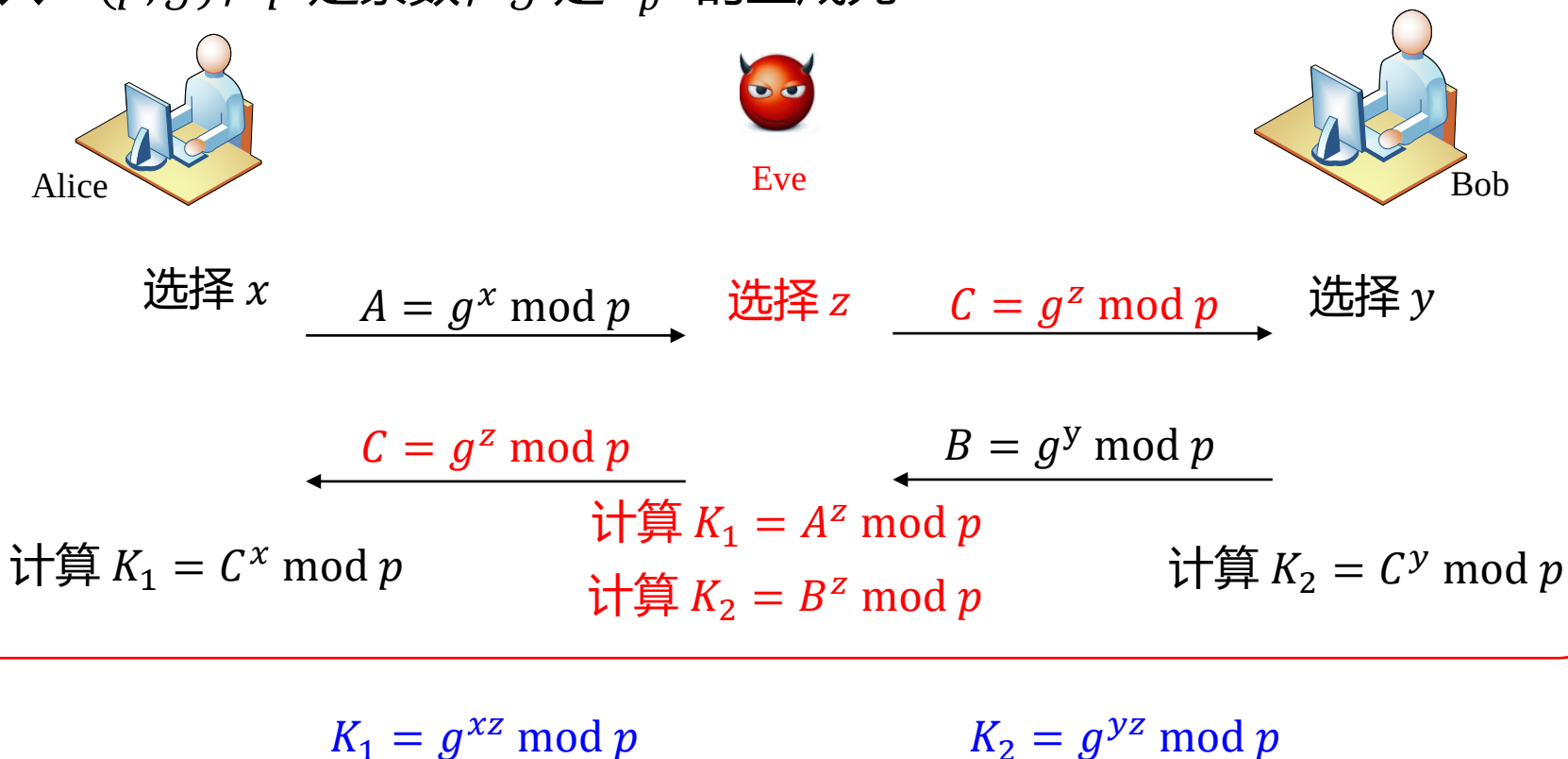
输出: 共享密钥 K

$$B^x \bmod p = (g^y \bmod p)^x \bmod p = g^{xy} \bmod p = (g^x \bmod p)^y \bmod p = A^y \bmod p$$



Diffie-Hellman 密钥交换协议无法抵抗中间人攻击。

输入: (p, g) , p 是素数, g 是 F_p^* 的生成元





1.3 公钥密码体制的进展

自从公钥密码的概念被提出以来，许多公钥密码体制被相继提出，如 RSA 密码体制、背包密码体制、McEliece 密码体制、ElGamal 密码体制等。在不断的研究和实践中，有些密码体制被攻破了，有些密码体制不太实用。关于最初十年的公钥密码体制的研究和发展，可参见文献 [1]。目前只有两种类型的公钥密码体制是安全实用的：基于大整数分解问题的密码体制；基于离散对数问题的密码体制。

一些新的密码体制正在被研究：

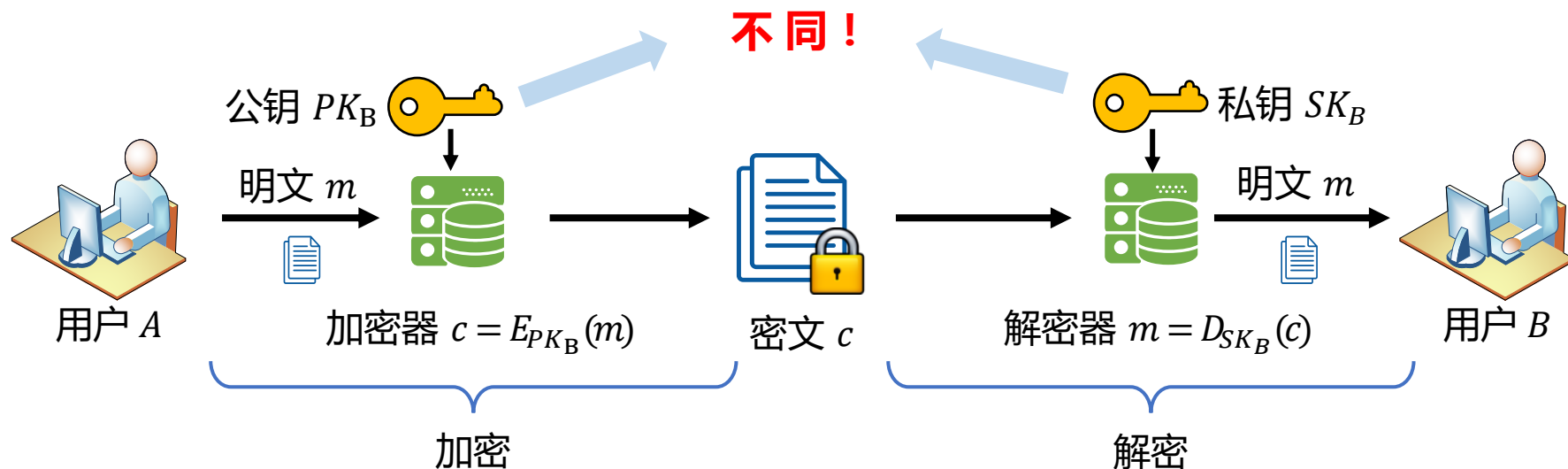
- 基于辫群的密码体制
- 后量子密码体制
- NTRU 密码体制
-

[1] W. Diffie. The first ten years of public-key cryptography. Proceeding of the IEEE, 76(5), 1988, 560-577.



1.4 公钥加密技术

公钥密码体制包括公钥加密和数字签名两种基本应用。公钥密码体制使用两个密钥：公钥和私钥，其中公钥被公开，私钥由用户保留。公钥加密技术实现了加密和解密操作的分离，不仅能够保证加密的安全性，同时也方便了密钥管理，因此被广泛应用。





1.4 公钥加密技术

一个公钥加密方案 $PKE = (Setup, Enc, Dec)$ 包含以下三个算法：

- **参数设置算法** $Setup(\lambda) \rightarrow (pk, sk)$ ：输入安全参数 λ ，产生一对密钥 (pk, sk) ，其中 pk 是公钥， sk 是私钥。它是概率性的多项式时间算法。
- **加密算法** $Enc(pk, m) \rightarrow c$ ：输入公钥 pk 和消息 m ，输出密文 c 。有时候该算法还会输入一些随机数。它是确定性/概率性的多项式时间算法。
- **解密算法** $Dec(sk, c) \rightarrow m$ ：输入私钥 sk 和密文 c ，输出消息 m 。它是确定性的多项式时间算法。

一个公钥加密方案需满足的要求：

- 公钥 pk 可以被任何人知道，用于加密。
- 由私钥和公开参数计算公钥容易。
- 私钥 sk 由消息接收者私有，用于解密。
- 由公钥及公开参数推导私钥困难。



2.1 单向函数

公钥加密要求加密函数具有单向性，即求逆的困难性。设计公钥加密体制的关键是**先要寻求一个合适的单向函数**。

- **单射**：令函数 f 是集合 A 到集合 B 的映射，以 $f: A \rightarrow B$ 表示。若对任意 $x_1 \neq x_2, x_1, x_2 \in A$ ，有 $f(x_1) \neq f(x_2)$ ，则称 f 为**单射**。
- **可逆**：函数 f 可逆的充要条件是存在函数 $g: B \rightarrow A$ ，使得对于所有 $x \in A$ ，有 $g[f(x)] = x$ 。此时 f 也为**满射**。
- **单向函数**：一个可逆函数 $f: A \rightarrow B$ ，若它满足：
 - 对所有 $x \in A$ ，易于计算 $f(x)$ 。
 - 对“几乎所有 $x \in A$ ”，由 $f(x)$ 求 x “**极为困难**”以至于实际上不可能做到，则称 f 为**单向 (One-way) 函数**。“**极为困难**”是针对现有的计算资源和算法而言。

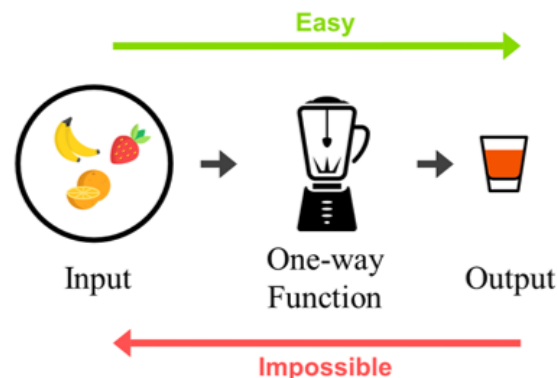


2. 陷门单向函数

2.1 单向函数

利用单向函数构造加密方案:

- 用正变换作加密，加密效率高；
- 用逆变换作解密，安全，敌手不可破译；
- 但是合法接收者也无法解密。



例 1 令 f 是有限域 $GF(p)$ 中的指数函数，其中 p 是大素数，即

$$y = f(x) = \alpha^x, \quad x \in GF(p)。$$

其逆运算是 $GF(p)$ 中定义的对数运算

$$x = \log_{\alpha} \alpha^x, \quad 0 \leq x < p - 1。$$

显然，由 x 求 y 是容易的，即使当 p 很大（如 $p \approx 2^{100}$ ）时也不难实现。如令 $\alpha = 2$ ，则所需的计算量为 $\lg p$ 次乘法，存储量为 $(\lg p)^2$ 比特。利用高速计算机由 x 计算 α^x 可在 0.1 毫秒内完成。反过来，即使利用计算 $GF(p)$ 中对数最好的算法，由 α^x 计算 x 需要大约 $10^{10.7}$ 秒（约为 1600 年）。



2.1 单向函数

当 p 很大时, 有限域 $GF(p)$ 中的指数函数 $f(x) = \alpha^x$ (其中 $x < p - 1$) 是一个单向函数。

在 $(p - 1)$ 无大素因子时, Pohlig 和 Hellman 于 1978 年给出了一种快速求对数的算法。特别是当 $p = 2^n + 1$ 时, 从 α^x 求 x 的计算量仅需 $(\log p)^2$ 次乘法。对于 $p = 2^{160} + 1$, 在高速计算机上大约仅需 10 毫秒。因此, 在这种情况下, $f(x) = \alpha^x$ 就**不能**被认为是单向函数。

因此, 对素数 p 且 $p - 1$ 有大的素因子时, $GF(p)$ 上的函数 $f(x) = \alpha^x$ 是一个单向函数。寻求在 $GF(p)$ 上求对数的一般快速算法是当前密码学研究中的一个重要课题。



2.2 陷门单向函数

显然，单向函数不能直接用作密码体制，因为如果用单向函数对明文进行加密，即使是合法的接收者也不能还原出明文（单向函数的逆运算是困难的）。与密码体制关系更为密切的概念是**陷门单向函数**。

陷门单向函数 (Trapdoor one-way function) 是在不知**陷门信息**下求逆困难的函数，当知道陷门信息后，求逆是易于实现的。

给陷门单向函数下定义是很棘手的！

- 陷门单向函数不是单向函数，因为后者是在任何条件下求逆都是困难的；
- 陷门可能不止一个，通过试验易找到逆。若陷门的保密性不强，求逆也就不难。



2.2 陷门单向函数

陷门单向函数：是一类满足下述条件的单向函数：

$$f_z: A_z \rightarrow B_z,$$

其中 $z \in Z$, Z 是陷门信息集。

- 对所有 $z \in Z$, 容易找到算法使得：对于所有 $x \in A_z$, 容易计算 f_z 及其逆。
- 若没有陷门 z , 对“几乎所有” $x \in A_z$, “很难”从 $y = f_z(x)$ 中计算出 x 。
- 对任一 $z \in Z$, 集合 A_z 必须是保密系统中明文集中的一个“方便”集, 即便于实现明文到它的映射 (在 PKC 中是默认的条件)。

Diffie 和 Hellman 定义的陷门函数中, $A_z = A$, 对所有 z 成立。而实际中的 A_z 取决于 z 。



2.2 陷门单向函数

1976 年 Diffie 和 Hellman 发表的文章中虽然没有给出陷门单向函数构造, 但大大推动了这方面的研究工作。公钥密码体制的研究在于给出这种函数的构造方法以及它们的安全性。

利用陷门单向函数构造公钥加密方案:

- 在一个公钥系统中, 所有用户共同选定一个陷门单向函数、加密运算 E 及可用消息集鉴别函数 F 。
- 用户 i 从陷门集中选定 z_i , 并公开 E_{z_i} 和 F_{z_i} 。
- 任意一个要向用户 i 发送机密消息 x 的用户, 可用 F_{z_i} 检验消息 x 是否在合法明文集之中, 然后发送 $y = E_{z_i}(x)$ 给用户 i 即可。
- 在仅知 y , E_{z_i} 和 F_{z_i} 下, 任一用户不能得到 x 。用户 i 利用陷门信息 z_i , 易于得到 $D_{z_i}(y) = x$ 。



2.3 公钥加密技术中所用的单向函数

(1) 大整数分解问题 (IF)

设 $n = pq$, 其中 p 和 q 是两个大素数。若已知 p 和 q , 求 $n = pq$ 只需一次乘法。但若已知 n , 求 p 和 q 满足 $n = pq$, 称为大整数分解问题, 则是几千年来数论专家的攻关对象。

已知的各种算法的渐近运行时间

试除法	$n/2$
二次筛法 (QS)	$O(\exp(\sqrt{(\ln n)(\ln \ln n)}))$
椭圆曲线 (EC)	$O(\exp(\sqrt{2(\ln p)(\ln \ln p)}))$
数域筛法 (NFS)	$O(\exp(1.92(\ln n)^{\frac{1}{3}}(\ln \ln n)^{\frac{2}{3}}))$



2.3 公钥加密技术中所用的单向函数

(2) RSA 问题

它是 IF 问题的一个特例。 n 是两个素数 p 和 q 之积, 给定 n 后求素因子 p 和 q 的相关问题称之为 **RSA 问题**。

$n = pq$ 分解的相关问题有以下几种形式:

- 分解整数 n 为 p 和 q (IF 问题)
- 给定整数 M 和 C , 求 d 使 $C^d \equiv M \pmod{n}$ (等价于 IF 问题)
- 给定整数 e 和 C , 求 M 使 $M^e \equiv C \pmod{n}$ (RSA 问题)
- 给定整数 C , 求 M 使 $M^2 \equiv C \pmod{n}$ (求解二次剩余问题)

求解模 n 的二次剩余问题等价于 IF 问题; 判定二次剩余问题也是困难问题。



2.3 公钥加密技术中所用的单向函数

(3) 离散对数问题 (DL)

给定一大素数 p (比如 p 在 2^{1024} 数量级), $p - 1$ 含另一大素数因子。
 $\{1, 2, \dots, p - 1\}$ 关于 $\text{mod } p$ 乘法构成了一个 $p - 1$ 阶循环群 $\mathbb{Z}_p^*$ 。该循环群的生成元一共有 $\varphi(p - 1)$ 个。

令 g 为循环群 $\mathbb{Z}_p^*$ 的一个生成元, $1 < g < p - 1$ 。随机选取一个整数 x , $1 < x < p - 1$ 。设 y 满足 $y = g^x \text{ mod } p$ 。已知 x, g, p , 求 $y = g^x \text{ mod } p$ 是容易的, 只需要 $(\text{lb } x) - 1$ 次乘法运算。

➤ **离散对数问题:** 若已知 y, g, p , 求 x 满足 $y = g^x \text{ mod } p$, 称为离散对数问题, 记为 $x = \log_g y \text{ mod } p$ 。



2.3 公钥加密技术中所用的单向函数

(3) 离散对数问题 (DL)

最快求解法运算次数渐近值为：

$$L(p) = O\left(\exp\left\{\left(1 + o(1)\right)\sqrt{\ln p \ln(\ln p)}\right\}\right)$$

当 $p = 512$ 比特时, $L(p) = 2^{256} \approx 10^{77}$ 。

若离散对数定义在 $GF(2^n)$ 中的 $2^n - 1$ 阶循环群上, 它的预计算量的渐近式为：

$$L(n) = O(\exp\{(1.405 + o(1))n^{1/3} (\ln n)^{2/3}\})$$

求一特定离散对数的计算量的渐近式为：

$$L(n) = O(\exp\{(1.098 + o(1))n^{1/3} (\ln n)^{2/3}\})$$



2.3 公钥加密技术中所用的单向函数

(4) 循环群上的困难问题

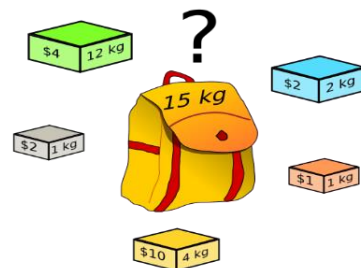
令 $\mathbb{G}$ 是由 g 生成的阶为素数 q 的循环乘法群。假定 $\mathbb{G}$ 的乘法和逆运算可以被有效地计算。下面讨论群 $\mathbb{G}$ 上的一些困难问题。

- **Discrete Logarithm Problem (DLP):** 给定两个元素 g 和 h , 找到一个整数 a , $a \in Z_q^*$, 满足 $h = g^a$ 。
- **Computation Diffie-Hellman Problem (CDHP):** 给定 (g, g^a, g^b) , 计算 $g^{ab} \bmod q$, 其中 $a, b \in Z_q^*$ 。
- **Decision Diffie-Hellman Problem (DDHP):** 给定 (g, g^a, g^b, g^c) , 判断 $c = ab \bmod q$ 是否成立, 其中 $a, b, c \in Z_q^*$ 。



3.1 背包密码体制的提出

背包密码体制由 Ralph Merkle 和 Martin Hellman 于 1978 年提出，是公钥密码体制的早期代表之一。背包密码体制的安全性依赖于 **背包问题**。



已知背包向量 $A = (a_1, a_2, \dots, a_n)$ ，其中 a_i 表示物品重量。给定向量 $\vec{x} = (x_1, x_2, \dots, x_n)$ ，其中 $x_i \in \{0, 1\}$ ，求和式 S （称为背包重量）容易：

$$S = a_1x_1 + a_2x_2 + \dots + a_nx_n$$

但已知 A 和 S ，求 $\vec{x}$ 则非常困难，该问题被称为**背包问题**，又称作**子集和 (Subset-Sum) 问题**。一般只能用穷举搜索法，有 2^n 种可能。当 n 很大时，求解相当困难。

[2] R. Merkle, M. Hellman. Hiding information and signatures in trapdoor knapsacks. IEEE Transactions on Information Theory, 24(5), 1978, 525-530.



3.2 超递增背包问题——背包问题的特例

将物品重量从小到大排列：

$$a_1, a_2, a_3, \dots, a_n。$$

如果

$$a_1 < a_2;$$

$$a_1 + a_2 < a_3;$$

$$a_1 + a_2 + a_3 < a_4;$$

...

$$a_1 + a_2 + a_3 + \dots + a_{n-1} < a_n;$$

称该背包问题为超递增背包问题。

设超递增背包重量为 S

贪婪算法的步骤如下：

(1) 穷举：寻找 k 满足

$$a_k < S < a_{k+1}。$$

(2) 记忆：存储这个 k 。

(3) 卸载：如果 $S > 0$ ，则令

$$S := S - a_k,$$

返回 (1)。

如果 $S = 0$ ，则直接跳到 (4)。

(4) 输出所存储的所有的 k ，停止。



3.3 算法描述

● 密钥生成:

- 随机选取 n 个具有超递增性的数值: $a_1, a_2, a_3, \dots, a_n$;
- 选取正整数 M, U , 满足 $(M, U) = 1$ 且

$$M > a_1 + a_2 + a_3 + \dots + a_n;$$

(M 和 U 互素时可计算出 U 关于 $\text{mod } M$ 的逆元 U^{-1})

- 对于 $i \in [n]$, 计算 $b_i = Ua_i \text{ mod } M$;
- 公钥为 $\{b_1, b_2, b_3, \dots, b_n\}$;
- 私钥为 $\{a_1, a_2, a_3, \dots, a_n\}, M, U$ 。



3.3 算法描述

- 加密:

设明文 $m = (m_1, m_2, m_3, \dots, m_n)$ 是长度为 n 的比特串, 使用公钥 $\{b_1, b_2, b_3, \dots, b_n\}$ 计算密文: $c = m_1b_1 + m_2b_2 + m_3b_3 + \dots + m_nb_n$ 。

- 解密:

使用私钥 $\{a_1, a_2, a_3, \dots, a_n\}, M, U$, 计算变换的密文 C :

$$\begin{aligned} C &= U^{-1}c \bmod M \\ &= U^{-1}(m_1b_1 + m_2b_2 + m_3b_3 + \dots + m_nb_n) \bmod M \\ &= m_1a_1 + m_2a_2 + m_3a_3 + \dots + m_na_n \bmod M \\ &= m_1a_1 + m_2a_2 + m_3a_3 + \dots + m_na_n \end{aligned}$$

使用贪婪算法求解 m 。



3.4 安全性及意义

- 安全性依赖于背包问题

- 若截获了密文 c ，又知道公钥 $\{b_1, b_2, b_3, \dots, b_n\}$ ，求解明文 m 是背包问题。
- 若已知变换密文 C ，又知道私钥 $\{a_1, a_2, a_3, \dots, a_n\}$ ，求解明文 m 就是超递增背包问题。

- 破译的基本思想

寻找 M' ， U' ，使得 $\{a'_1, a'_2, a'_3, \dots, a'_n\}$ 为超递增背包向量，其中 $a'_i = U'b_i \bmod M'$ 。计算背包重量 $C' = U'c \bmod M'$ 。使用贪婪算法求解便可获得 $m = (m_1, m_2, m_3, \dots, m_n)$

- 背包密码体制在密码学中的重要意义

- 它是第一个公开发表的基于“困难问题”的公钥密码体制，对后来的公钥密码体制的研究有着重要的启示作用。
- 它的安全性基于背包问题的困难性，为研究背包问题提供了一种新的研究途径。



4.1 RSA 加密体制

MIT 三位数学家 Ronald Rivest、Adi Shamir 和 Leonard Adleman 于 1977 年给出了首个陷门单向函数的构造实例。他们提出了 MIT 体制，该工作于 1978 年发表，后被广泛称为 **RSA 体制**。



RSA 体制既可用于加密、又可用于数字签名，易懂且易于实现，是目前仍然安全并且逐步被广泛应用的一种体制。

国际上一些标准化组织 ISO、ITU 及 SWIFT 等均已接受 RSA 体制作为标准。在 Internet 中所采用的 PGP (Pretty Good Privacy) 中也将 RSA 作为传送会话密钥和数字签字的标准算法。

[3] R. Rivest, A. Shamir, L. Adleman. A method for obtaining digital signatures and public-key cryptosystems. Communications of the ACM (CACM), 21(2), 1978, 120-126.



4.2 算法描述

● 密钥生成:

1. 选取两大素数 p 和 q (约为 512 比特数), 计算 $n = pq$, 其欧拉函数值为 $\varphi(n) = (p-1)(q-1)$ 。
2. 随机选一整数 e , $1 \leq e < \varphi(n)$, $(\varphi(n), e) = 1$ 。
3. 计算 e 的逆元 $d = e^{-1} \bmod \varphi(n)$ 。
4. 公钥为 (n, e) , 私钥为 d (p 和 q 不再需要, 可以销毁)。

陷门函数: $Z = (p, q, d)$

明文表示: 将明文分组, 各组在 $\bmod n$ 下可惟一地表示 (以二元数字表示, 选 2 的最大幂小于 n)。可用明文集 $A_Z = \{m: 1 \leq m < n, (m, n) = 1\}$ 。

注意: $(m, n) \neq 1$ 是很危险的

$$m \in A_Z \text{ 的概率为: } \frac{\varphi(n)}{n} = \frac{(p-1)(q-1)}{pq} = 1 - \frac{1}{p} - \frac{1}{q} + \frac{1}{pq} \rightarrow 1$$



4.2 算法描述

- 加密:

使用公钥 (n, e) 对明文 m ($0 < m < n$) 加密, 计算密文为

$$c = m^e \bmod n$$

- 解密:

使用公钥 (n, e) 和私钥 d 对密文 c 解密, 计算

$$m' = c^d \bmod n$$

解密原理

$c^d = (m^e)^d = m^{de} \bmod n$, 因为 $de = 1 \bmod \varphi(n)$ 而有 $de = q\varphi(n) + 1$ 。

由 Euler 定理, $(m, n) = 1$ 意味着 $m^{\varphi(n)} \equiv 1 \bmod n$, 故有

$$m' = cd = m^{de} = m^{q\varphi(n)+1} \equiv m \cdot m^{q\varphi(n)} = m \cdot 1 = m \bmod n$$



4.3 安全性

- RSA 加密算法的安全性基于 RSA 问题

RSA问题:

输入: $n = pq$ (p 和 q 是大素数) ,

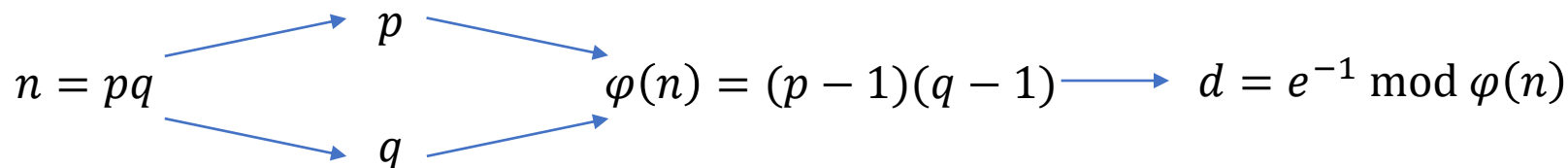
整数 e 满足 $(\varphi(n), e) = 1$,

$c \in \mathbb{Z}_n^*$

输出: $m \in \mathbb{Z}_n^*$ 使 $m^e = c \bmod n$



- RSA 问题的困难性依赖于大整数分解问题的困难性





4.3 安全性

(1) 分解模数 n

理论上, RSA 的安全性取决于模 n 分解的困难性, 但数学上至今还未证明分解模就是攻击 RSA 的最佳方法, 也未证明分解大整数就是 NP 问题, 可能有尚未发现的多项式时间分解算法。

人们完全可以设想有另外的途径破译 RSA, 如求解密指数 d 或找到 $(p - 1)(q - 1)$ 等, 但这些途径并不比分解 n 更容易。

Alexi 等已证明, 从 RSA 加密的密文恢复某些 bit 的困难性也和恢复整组明文一样困难。这一困难性问题是 NP 问题, 但还没人证明它为 NPC 问题。



4.3 安全性

(2) 求 $\varphi(n)$

从 n 若能求出 $\varphi(n)$, 则可求得 p 和 q 。因为

$$n - \varphi(n) + 1 = pq - (p - 1)(q - 1) + 1 = p + q$$

而 $\sqrt{(p + q)^2 - 4n} = p - q$ 。从而得到 p 和 q 。

所以, 求 $\varphi(n)$ 的困难性等价于分解 n 的困难性。

从 n 求 d 的困难性亦等价于分解 n 的困难性。目前尚不知是否存在一种无需籍助于分解 n 的攻击法; 也未能证明破译 RSA 的任何方法都等价于大整数分解问题。



4.3 安全性

(3) 迭代攻击法

Simmons 和 Norris 曾提出迭代（循环）攻击法，即迭代地对密文 c 加密多次，直到再现 c 为止。

例如，给定 RSA 的参数为 $(n, e, c) = (35, 17, 3)$ 。首先，对 $c_0 = c = 3$ 加密得到

$$c_1 = 3^{17} = 33 \bmod 35。$$

然后再对 c_1 加密得到

$$c_2 = c_1^{17} = 3 \bmod 35。$$

由此可知明文 $m = c_1 = 33 \bmod 35$ 。

Rivest 证明，当 $p - 1$ 和 $q - 1$ 中含有大素数因子，且 n 足够大时，这种攻击法成功的概率趋于 0。



4.3 安全性

(4) 低指数攻击

假设发送者将消息 m 发送给三个接收者，每个接收者的公钥都为 $e = 3$ ，每个接收者的模数分别为 n_1, n_2, n_3 。要求三个模数两两互素，否则，可求出公因子，而降低安全性。



$$\begin{cases} c_1 = m^3 \bmod n_1 \\ c_2 = m^3 \bmod n_2 \\ c_3 = m^3 \bmod n_3 \end{cases}$$

中国剩余定理

$$\xrightarrow{\text{中国剩余定理}} M = m^3 \bmod n_1 n_2 n_3$$

因为 $m < n_i$ ($i = 1, 2, 3$)，所以 $m^3 < n_1 n_2 n_3$ ，故有 $m = \sqrt[3]{M}$ 。



4.3 安全性

(5) 共模攻击

假设发送者在将消息 m 发送给两个不同的接收者时使用相同的模数 $n = pq$ 。两个接收者的公钥分别为 e_1 和 e_2 , $(e_1, e_2) = 1$ 。密文分别为 $c_1 = m^{e_1} \bmod n$ 和 $c_2 = m^{e_2} \bmod n$ 。



扩展 Euclid 算法

计算 r, s ($r < 0$),
使 $re_1 + se_2 = 1$

计算 $c_1^{-1} \bmod n$

$$m = (c_1^{-1})^{-r} c_2^s \bmod n$$

还有两种攻击共用模 RSA 的方法：用概率方法可分解 n 、用确定性算法可计算某一用户的密钥而不需要分解 n 。



4.3 安全性

(6) 主动攻击

攻击者可以冒充合法用户、伪造信息主动和目标用户进行交互，从而获得想要的信息，将攻击者的能力抽象出来就是可以查询解密 Oracle 获取任意密文（除挑战密文）对应的明文。假设攻击者得到了使用公钥 e 加密的密文 $c = m^e \bmod n$ ，敌手的目标是计算出消息 m 。

攻击者选择随机数 $r \in \mathbb{Z}_n^*$ ，计算

$$c_1 = r^e \bmod n, \quad c_2 = c_1 \times c \bmod n.$$

现在攻击者请 A 对密文 c_2 进行解密得到 $s = c_2^d \bmod n$ 。然后攻击者计算

$$s/r \bmod n = m,$$

得到了明文 m 。（解密 Oracle 不能随便使用）



4.3 安全性

(7) 中间相遇攻击

RSA 加密具有乘法同态性质：

$$(m_1 \cdot m_2)^e = m_1^e \cdot m_2^e = c_1 \cdot c_2 \bmod n。$$

该性质表明如果明文容易分解，则相应的密文也容易分解。

假设消息 $m < 2^l$ ，则 m 以不可忽略的概率满足 $m = m_1 \cdot m_2$ ，其中 $(m_1, m_2 < 2^{\frac{l}{2}})$ 。由RSA加密的可乘性质可知 $c = m_1^e \cdot m_2^e \bmod n$ 。



攻击者

- ① 创建有序序列 $\{1^e, 2^e, \dots, (2^{\frac{l}{2}})^e\} \bmod n$;
- ② 计算 $\frac{c}{i^e} \bmod n$ ，其中 $i = 1, 2, \dots, 2^{\frac{l}{2}}$;
- ③ 遍历序列寻找满足 $\frac{c}{i^e} = j^e \bmod n$ 的 j ，计算 $m = i \cdot j$ 。



4.3 安全性

(8) 定时攻击

定时 (Timing) 攻击法由 P. Kocher 提出, 利用测定 RSA 解密所进行的模指数运算的时间来估计解密指数 d , 而后再精确定出 d 的取值。

Rivest 曾指出, 这一攻击法可以通过将解密运算量与参数 d 无关挫败。另外还可采用盲化技术, 即先将数据盲化, 再进行加密运算, 而后做去盲运算。这样做虽然不能使解密运算时间保持不变, 但计算时间被随机化而难于推测解密所进行的指数运算的时间。

(9)

[4] D. Boneh. Twenty years of attacks on the RSA cryptosystem. Notices of the American Mathematical Society, 46(2):203-213, 1999. <http://crypto.stanford.edu/~dabo/abstracts/RSAattack-survey.html>



4.4 参数的选择

(1) n 的选择

- ① $n = p \times q$, p 与 q 必须为**强素数**。

强素数 p 的条件:

- 存在 2 个大素数 p_1 和 p_2 , 使得 $p_1 | (p - 1)$, $p_2 | (p + 1)$ 。
- 存在 4 个大素数 r_1, s_1, r_2 及 s_2 , 使得 $r_1 | (p_1 - 1)$, $s_1 | (p_1 + 1)$, $r_2 | (p_2 - 1)$, $s_2 | (p_2 + 1)$ 。

称 r_1, s_1, r_2 和 s_2 为**三级素数**; p_1 和 p_2 为**二级素数**。

- ② p 与 q 要足够大, 以使 n 的分解在计算上不可行。
- ③ p 与 q 之差要大, 否则可由 $n = pq$ 大致估计 $\frac{p+q}{2} = \sqrt{n}$, 此外有 $\left(\frac{p+q}{2}\right)^2 - n = \left(\frac{p-q}{2}\right)^2$ 。最后由 $\frac{p+q}{2}$ 和 $\frac{p-q}{2}$ 可以得到 p 和 q 。



4.4 参数的选择

(1) n 的选择

- ④ $p - 1$ 与 $q - 1$ 的最大公因子要小。

在惟密文攻击下，假设攻击者已截获密文 $c = m^e \bmod n$ 。攻击者做下述计算（迭代攻击法）：

$$m_i = m_{i-1}^e = (m)^{e^i} \bmod n$$

若 $e^i = 1 \bmod \varphi(n)$ ，则有 $m_i = m \bmod n$ ，且 $e^{i+1} = e \bmod \varphi(n)$ 。即 $m_{i+1} = c$ 。若 i 小，则由此攻击法易得明文 m 。

由 Euler 定理知， $i = \varphi((p - 1)(q - 1))$ 。若 $p - 1$ 和 $q - 1$ 的最大公因子小，则 i 值大。如 $i = (p - 1)(q - 1)/2$ ，则此方法难于奏效。



4.4 参数的选择

(2) e 的选择

e 小, 加密速度快, Knuth 和 Shamir 曾建议采用 $e = 3$ 。但 e 太小易受到低指数攻击。而且若 e 小, m 小, 当 $m^e < n$ 时, 则 $c = m^e \bmod n = m^e$, 由 c 直接开 e 次方可求 m 。

(3) d 的选择

d 小, 签名和解密速度快, 这在 IC 卡中尤为重要 (复杂的加密和验证签名可由主机来做)。类似于加密的情况, d 不能太小, 否则存在已知明文攻击。Wiener 证明了当 d 长度小于 n 的 $1/4$ 时, 由连分式算法, 可在多项式时间内求出 d 值。因此, d 要大于 $n^{1/4}$ 。这是否可推广至 $1/2$ 还不知道。

(4) 不要让许多用户共用一个模 n



4.5 方案的实现

(1) 大素数的产生

- 概率性产生

目前最常用的概率性算法是 Miller-Rabin 概率检测法。Miller-Rabin 概率检测法已经成为美国的国家标准。

寻找大素数时一般是先随机选取一个大的奇数（例如用伪随机数产生器），然后用素性检验算法检验这一奇数是否为素数，如果不是则选取另一大奇数，重复这一过程，直到找到素数为止。

- 确定性产生

- 确定性测试

- 确定性构造



4.5 方案的实现

(2) 大素数的计算

- 模指数算法

求 a^m 可如下进行, 其中 a, m 是正整数:

将 m 表示为二进制形式 $b_k b_{k-1} \cdots b_0$, 即

$$m = b_k 2^k + b_{k-1} 2^{k-1} + \cdots + b_1 2 + b_0$$

因此

$$a^m = \left(\cdots \left(\left((a^{b_k})^2 a^{b_{k-1}} \right)^2 a^{b_{k-2}} \right)^2 \cdots a^{b_1} \right)^2 a^{b_0}$$

例如求 x^{16} , 直接计算的话需做 15 次乘法。然而如果重复对每个部分结果做平方运算即求 x, x^2, x^4, x^8, x^{16} , 则只需 4 次乘法。



4.5 方案的实现

● 硬件实现

速度最快也只为 DES 的 $1/1000$ ，512 bit 模下的 VLSI 硬件实现只有 64 kb/s。1024 bit RSA 加密芯片也在开发中。人们在努力将 RSA 体制用于灵巧卡技术中。

● 软件实现

速度只为 DES 的软件实现的 $1/100$ ，512 bit RSA 的软件实现的速率可达 11 kb/s。RSA 多用于密钥交换和认证。

如果适当选择 RSA 的参数，可以大大加快速度。例如，选 e 为 3、17 或 $65537(2^{16} + 1)$ 的二进制表示式中都只有两个 1，大大减少了运算量。X. 509 建议用 65537，PEM 建议用 3，PKCS#1 建议用 65537，当消息后填充随机数字时，不会有任何安全问题。



4.6 RSA 模数的分解

采用广义数域筛分解不同长度 RSA 公钥模所需的计算机资源

密钥长(bit)	所需的 MIPS-年*
116 (Blacknet 密钥)	400
129	5,000
512	30,000
768	200,000,000
1024	300,000,000,000
2048	300,000,000,000,000,000,000

* MIPS-年指以每秒执行 1,000,000 条指令的计算机运行一年



4.6 RSA 模数的分解

当前的技术进展使分解算法和计算能力不断提高，计算所需的硬件费用在不断下降，原来被认为是不可能分解的大数已被成功分解。

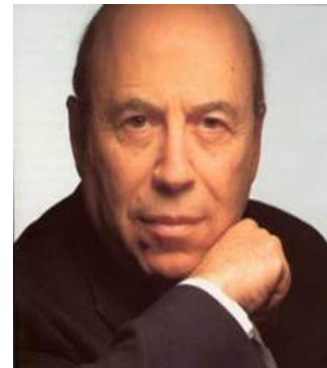
- RSA-129: Rivest 等最初悬赏 \$100 攻击 RSA-129，已由包括五大洲 43 个国家 600 多人参加，用1600台机器同时产生820条指令数据，通过 Internet 网，耗时8个月，于 1994 年 4 月 2 日利用二次筛法分解出为 64 位和 65 位的两个因子，原来估计要用 4 亿亿年。
- RSA-130 于 1996 年 4 月 10 日利用数域筛法分解出来。
- RSA-140 于 1999 年 2 月分解出来。
- RSA-155 (512 bit) 于 1999 年 8 月分解出来。
- RSA-232 (768 bit) 于 2009 年 12 月分解出来。
- RSA-240 (795 bit) 于 2019 年 12 月分解出来。





5.1 Rabin 加密体制

1979年，以色列计算机科学家 Michael Oser Rabin 构造了一种安全公钥体制，该体制基于以下事实：在已知 n 的分解形式的情况下，计算关于合数模 n 的平方根是简单的，但是不知道 n 的分解形式时，计算关于合数模 n 的平方根是困难的。



Michael Oser Rabin

Rabin 加密方案在形式上与 RSA 加密类似，但 Rabin 体制的**安全性完全等价于分解大整数**。很具有讽刺意义的是，教科书式的 Rabin 体制即使是可证明安全的，也很容易遭受到攻击。

[5] M. Rabin. Digitalized signatures and public-key functions as intractable as factorization. MIT Laboratory for Computer Science Technical Report, 212, 1979.



5.2 算法描述

● 密钥生成:

1. 选择两个大的素数 p, q ($p = q = 3 \bmod 4$), 计算 $n = pq$ 。
2. 公钥为 n , 私钥是 (p, q) 。

● 加密:

使用公钥 n 加密明文 m ($0 < m < n$), 计算密文为 $c = m^2 \bmod n$ 。

● 解密:

1. 使用私钥 (p, q) 对密文 c 解密, 求解
$$\begin{cases} m^2 = c \bmod p \\ m^2 = c \bmod q \end{cases}$$
 得到 4 个值 m_1, m_2, m_3, m_4 。
2. 排除没有语义的“乱码”, 得到真正的明文 m 。



5.3 解密原理

当 $p = q = 3 \bmod 4$ 时, 两个方程 $m^2 = c \bmod p$ 和 $m^2 = c \bmod q$ 的平方根都容易求出。

由 $p = 3 \bmod 4$ 得 $p + 1 = 4k$, 即 $\frac{p+1}{4}$ 是整数。因 c 是模 p 的平方剩余, 故

$$\left(\frac{c}{p}\right) \equiv c^{(p-1)/2} \equiv 1 \bmod p$$

设 $m^2 = c \bmod p$ 的根为 y , 即 $y^2 = c \bmod p$, 则

$$\left(c^{\frac{p+1}{4}}\right)^2 \equiv \left(y^{\frac{p+1}{2}}\right)^2 \equiv (y^2)^{\frac{p+1}{2}} \equiv c^{\frac{p+1}{2}} \equiv c^{(p-1)/2} \cdot c \equiv c \bmod p$$

所以 $c^{\frac{p+1}{4}}$ 和 $p - c^{\frac{p+1}{4}}$ 是方程 $m^2 = c \bmod p$ 的两个根。

同理, $c^{\frac{q+1}{4}}$ 和 $q - c^{\frac{q+1}{4}}$ 是方程 $m^2 = c \bmod q$ 的两个根。



5.3 解密原理

因此, $\begin{cases} m^2 = c \bmod p \\ m^2 = c \bmod q \end{cases}$ 等价于以下 4 个同余方程组

$$\begin{cases} m = c^{\frac{p+1}{4}} \bmod p \\ m = c^{\frac{q+1}{4}} \bmod q \end{cases}$$

$$\begin{cases} m = c^{\frac{p+1}{4}} \bmod p \\ m = q - c^{\frac{q+1}{4}} \bmod q \end{cases}$$

$$\begin{cases} m = p - c^{\frac{p+1}{4}} \bmod p \\ m = c^{\frac{q+1}{4}} \bmod q \end{cases}$$

$$\begin{cases} m = p - c^{\frac{p+1}{4}} \bmod p \\ m = q - c^{\frac{q+1}{4}} \bmod q \end{cases}$$



5.3 解密原理

由中国剩余定理可解出每一方程组的解为

$$m_1 = \left(u \cdot c^{\frac{p+1}{4}} + v \cdot c^{\frac{q+1}{4}} \right) \bmod n$$

$$m_2 = \left(u \cdot c^{\frac{p+1}{4}} + v \cdot \left(q - c^{\frac{q+1}{4}} \right) \right) \bmod n$$

$$m_3 = \left(u \cdot \left(p - c^{\frac{p+1}{4}} \right) + v \cdot c^{\frac{q+1}{4}} \right) \bmod n$$

$$m_4 = \left(u \cdot \left(p - c^{\frac{p+1}{4}} \right) + v \cdot \left(q - c^{\frac{q+1}{4}} \right) \right) \bmod n$$

其中 $u = q(q^{-1} \bmod p)$, $v = p(p^{-1} \bmod q)$ 。每一密文对应的明文不惟一，为了有效确定明文，在加密时可在 m 中注入某些信息（如身份、日期等）。



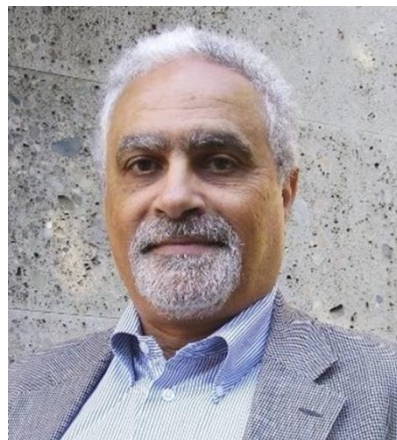
5.4 Rabin 与 RSA 的比较

	Rabin 加密	RSA 加密
公钥	n	(n, e)
私钥	(p, q)	d
加密算法	$c = m^2 \bmod n$	$c = m^e \bmod n$
解密算法	$\begin{cases} m^2 = c \bmod p \\ m^2 = c \bmod q \end{cases}$ 求解每个方程，组合为 4 个方程组，分别对每个方程组求解	$m = c^d \bmod n$
安全基础	等价于大整数分解困难性	基于大整数分解困难性



6.1 ElGamal 加密体制

1984 年，密码学家 Tather ElGamal 在 CRYPTO 1984 上提出了一种基于离散对数问题的公钥密码体制。该密码体制既可用于加密，又可用于数字签名。ElGamal 密码体制与 Diffie-Hellman 密钥交换协议密切相关。



Tather ElGamal

ElGamal 加密是最早的非确定性公钥加密方案。ElGamal 密码体制的安全性是基于有限域乘法群 $\mathbb{Z}_p^*$ 上的离散对数问题的困难性。

[6] T. ElGamal. A public key cryptosystem and a signature scheme based on discrete logarithms. Proceedings of CRYPTO 1984, 10-18, 1984.



6.2 算法描述

- 密钥生成:

1. 选择一个大的素数 p 和 $\mathbb{Z}_p^*$ 的一个生成元 g 。
2. 选择 $x \in \mathbb{Z}_p^*$, 计算 $y = g^x \bmod p$ 。
3. 公钥是 (p, g, y) , 私钥是 x 。

- 加密: 使用公钥 y 加密明文 m ($0 < m < p$):

1. 选择随机数 k 满足 $(k, p-1) = 1$, 计算
$$c_1 = g^k \bmod p, \quad c_2 = m \cdot y^k \bmod p.$$
2. 密文 $c = (c_1, c_2)$ 。

- 解密:

使用私钥 x 对密文 c 解密, 计算 $m = \frac{c_2}{c_1^x} = \frac{m \cdot y^k}{g^{kx}} = \frac{m \cdot g^{xk}}{g^{xk}} \bmod p$ 。



6.3 安全性

(1) 中间相遇攻击

ElGamal 加密一般采用阶为 $r = \text{ord}(g) \ll p$ 的 g 来提高效率。

已知密文 $(c_1, c_2) = (g^k, m \cdot y^k) \bmod p$, 如果消息 $m \notin \mathbb{Z}_p^*$, 则攻击者能够得到 $c_2^r = m^r \bmod p$ 。即攻击者将 ElGamal 的“概率”加密体制转化为一种确定性的！

因此，对于一条容易分解的小消息，与对 RSA 加密的攻击完全一样，攻击者也能够对 $m \bmod p$ 进行中间相遇攻击。



6.3 安全性

(2) 主动攻击

攻击者收集用公钥 (p, g, y) 加密的密文

$$c = (c_1, c_2) = (g^k, m \cdot y^k) \bmod p,$$

目标是分析出消息 m 。

选择随机数 $r \in \mathbb{Z}_p^*$, 计算 $c'_2 = r \cdot c_2 \bmod p$ 。现在攻击者请 A 对密文 (c_1, c'_2) 进行解密得到 $s = \frac{c'_2}{c_1^x} \bmod p$ 。然后通过计算 $s/r \bmod p = m$, 攻击者得到了明文 m 。 (**不能随意调用解密 Oracle**)

此外, 也要注意 ElGamal 加密的乘法同态性。如何攻击?



6.4 参数选择

- p 应为 150 位（十进制数）以上的大素数，而且 $p - 1$ 应有大素因子。

由于 ElGamal 加密的安全性建立在 $\mathbb{Z}_p^*$ 离散对数的困难性上，而目前尚无求解 $\mathbb{Z}_p^*$ 离散对数的有效算法，所以在 p 足够大时 ElGamal 加密是安全的。

- 私钥 x 和随机数 k 都不能太小。
- 加密所使用的 k 必须是一次性的。

如果重复使用随机数 k ，时间长了就可能被攻击者暴力破解，从而计算出 $U = y^k \bmod p$ ，进而利用扩展 Euclid 算法求出 $U^{-1} \bmod p$ 。又因为攻击者可以获得密文 c_2 ，于是可以计算出 $m = U^{-1}c_2 \bmod p$ 。



7.1 Paillier 加密体制

1999 年, Pascal Paillier 在 EUROCRYPT 1999 上提出了一个支持加法同态的公钥密码系统——Paillier 加密。此后, PKC 2001 中 Paillier 方案的简化版本被提出, 这是当前最优的 Paillier 方案。在众多半同态加密 (PHE) 方案中, Paillier 方案由于效率较高、安全性证明完备的特点, 在实际应用中被广泛使用, 是目前隐私计算场景中最常用的 PHE 实例化方案之一。



Pascal Paillier

[7] P. Paillier. Public-key cryptosystems based on composite degree residuosity classes. Proceedings of EUROCRYPT 1999, 223-238, 1999.



7.2 合数剩余问题

Paillier 加密方案使用群 $\mathbb{Z}_{N^2}^*$ ，依赖于合数剩余问题。

命题 1 设 $N = pq$ ，其中 p 和 q 为素数。则：

- 对于任意的整数 $a \geq 0$ ，可得 $(1 + N)^a = (1 + aN) \bmod N^2$ 。
- 定义同态函数 $f: \mathbb{Z}_N \times \mathbb{Z}_N^* \rightarrow \mathbb{Z}_{N^2}^*$ 为： $f(a, b) = (1 + N)^a \cdot b^N \bmod N^2$ ，
其中 $\mathbb{Z}_N$ 为模 N 加法群， $\mathbb{Z}_N^*$ 为模 N 乘法群。如果 $f(a, b) = y \in \mathbb{Z}_{N^2}^*$ ，
记作 $y \leftrightarrow (a, b)$ 。

如果 $y \in \mathbb{Z}_{N^2}^*$ 是模 N^2 的 N 次剩余，那么存在一个 $x \in \mathbb{Z}_{N^2}^*$ 满足 $y = x^N \bmod N^2$ 。假设 $\text{Res}(N^2)$ 表示模 N^2 的 N 次剩余的集合。

➤ 判定合数剩余问题：

给定 $N = pq$ ，其中 p 和 q 为素数，判断随机数 r 属于 $\text{Res}(N^2)$ 还是 $\mathbb{Z}_{N^2}^*$ 。



7.3 算法描述

- 密钥生成:

1. 选择两个大的素数 p 和 q , 计算 $N = pq$ 。
2. 公钥是 N , 私钥是 $(N, \varphi(N))$ 。

- 加密: 使用公钥 N 加密明文 $m \in \mathbb{Z}_N$:

1. 选择随机数 $r \in \mathbb{Z}_N^*$, 计算 $c = (1 + N)^m \cdot r^N \bmod N^2$ 。

- 解密: 使用私钥 $(N, \varphi(N))$ 对密文 c 进行解密:

1. 计算 $\hat{m} = \frac{c^{\varphi(N)} \bmod N^2 - 1}{N}$ 。
2. 通过 $m = \hat{m} \cdot \varphi(N)^{-1} \bmod N$ 将明文 m 恢复出来。



7.4 解密原理

$f: \mathbb{Z}_N \times \mathbb{Z}_N^* \rightarrow \mathbb{Z}_{N^2}^*$, 其中 $\mathbb{Z}_N$ 为模 N 加法群, $\mathbb{Z}_N^*$ 为模 N 乘法群。

如果 $y = f(a, b) = (1 + N)^a \cdot b^N \bmod N^2$, 记作 $y \leftrightarrow (a, b)$ 。

因为 $c = (1 + N)^m \cdot r^N \bmod N^2 \leftrightarrow (m, r)$, 则有

$$\begin{aligned}\hat{c} &= c^{\varphi(N)} \bmod N^2 \\ &\leftrightarrow (m, r)^{\varphi(N)} \\ &= (\varphi(N) \cdot m \bmod N, r^{\varphi(N)} \bmod N) \\ &= (\varphi(N) \cdot m \bmod N, 1) \\ &\leftrightarrow (1 + N)^{m \cdot \varphi(N) \bmod N} \bmod N^2 \\ &= [1 + (m \cdot \varphi(N) \bmod N) \cdot N] \bmod N^2 \\ &= 1 + (m \cdot \varphi(N) \bmod N) \cdot N\end{aligned}$$

于是 $\hat{m} = \frac{\hat{c}-1}{N} = m \cdot \varphi(N) \bmod N$, 最终 $m = \hat{m} \cdot \varphi(N)^{-1} \bmod N$ 。



7.5 性质

● 加法同态性

Paillier 加密满足加法同态性。对于任意的 $m_1, m_2 \in \mathbb{Z}_N$, 有

$$Dec(Enc(m_1) \cdot Enc(m_2) \bmod N^2) = m_1 + m_2 \bmod N$$

该性质在电子选举、门限加密方案、数字水印、秘密共享方案及安全多方计算等领域有重要应用。

● 重加密

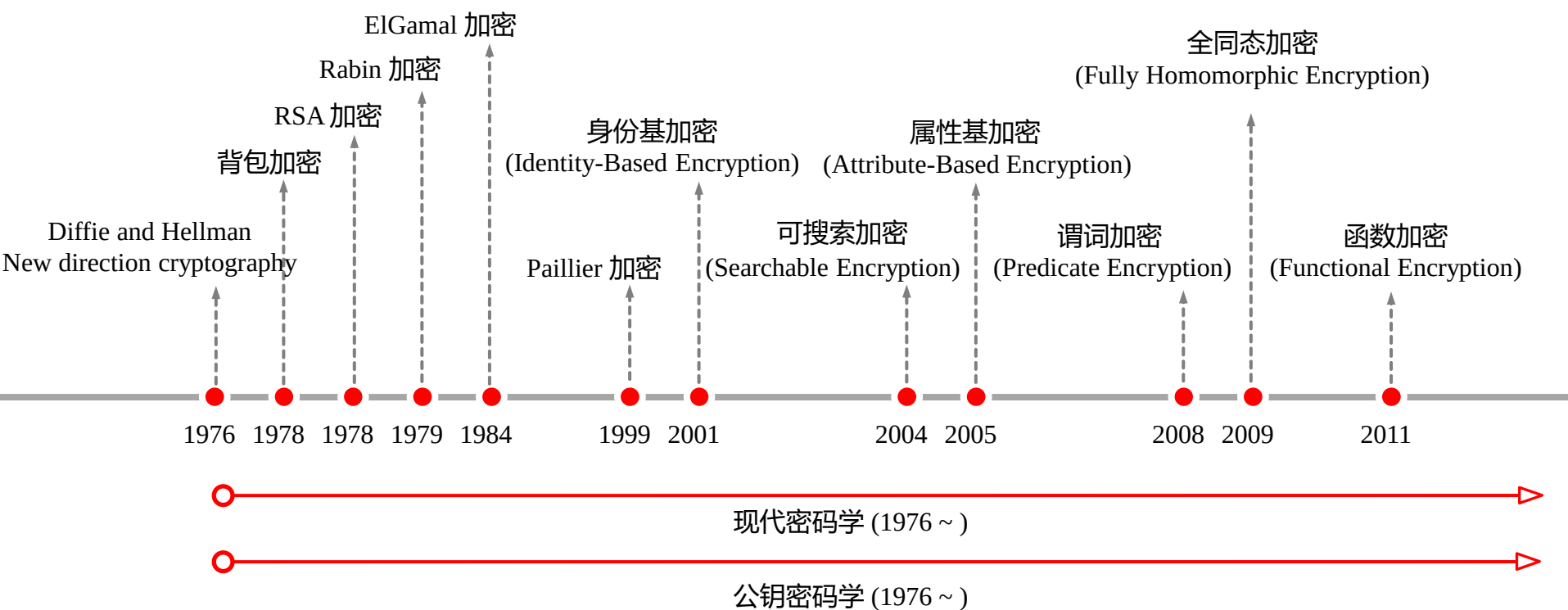
重加密 RE (re-encryption) 是指已知密文 c , 在不改变对应的明文的前提下, 可以将 c 变为另一个密文 c' 。对于任意的 $m \in \mathbb{Z}_N$, $r \in N$, 有

$$Enc(m) = Enc(m) \cdot Enc(0) = Enc(m) \cdot r^N \bmod N^2。$$

因此 $Dec(Enc(m) \cdot r^N \bmod N^2) = m。$



公钥加密技术的发展历程





8.1 教科书式公钥加密体制的安全性

教科书安全性 (Textbook Security) :

- 完全或无保密 (All-or-nothing secrecy)

对一个密码算法的特定的输出密文 C , 攻击者任务是得到相应的 (整个分组) 明文, 其大小与系统的安全参数有关; 或者给定一个密码算法的明文-密文对, 攻击者的任务是恢复相应的密钥。攻击者要么成功地完全得到想要的秘密, 要么什么也得不到。

- 抵抗被动攻击

攻击者不能运用自己掌握的数据操纵修改密文, 也不能要求拥有密钥的用户提供加密或解密服务。

这种安全性 (保密性) 的定义非常弱。实际中没有多大用处, 所以称之为 “**不安全性定义**” 比较合适。



(1) Textbook RSA 加密的不安全性

定理 2 RSA 系统在 CPA 下满足 All-or-nothing secrecy 当且仅当 RSA 假设 (给定 n, e, c , 求解 m 满足 $m^e = c \bmod n$) 成立。

证明:

$\Rightarrow$ 设 RSA 假设不成立, 那么给定密文 $c = m^e \bmod n$, 公钥 (n, e) , 存在预言机 $\mathcal{O}$ 以不可忽略的概率在给定 (n, e, c) 时输出 m 。因为 m 就是密文 c 对应的明文, 与 RSA 加密方案安全相矛盾。

$\Leftarrow$ 设 RSA 加密系统是不安全的, 那么对于 RSA 加密系统, 存在预言机 $\mathcal{O}$, 在给定公钥 (n, e) 和密文 c 时, 以不可忽略概率获得明文 m , 即 $m \leftarrow \mathcal{O}(n, e, c)$, 与 RSA 假设成立相矛盾。



(2) Textbook Rabin 加密的不安全性

定理 3 设 $n = pq$, $y = x^2 \bmod n$, 其中 p 和 q 是素数, $x \in \mathbb{Z}_n$ 。则求得 y 的四个平方根具有以下性质:

- 这 4 个根各不相同, 且 $x_1 + x_4 = x_2 + x_3 = n$;
- $\gcd(x_1 + x_2, n) = \gcd(x_3 + x_4, n) = q$, $\gcd(x_1 + x_3, n) = \gcd(x_2 + x_4, n) = p$ 。

定理 4 Rabin 系统在 CPA 下满足 All-or-nothing secrecy 当且仅当整数分解假设 (给定 n , 寻找 $p|n$) 成立。

证明:

⇒ 解密需要分解模 n , 如果 Rabin 系统是安全的, 那么 IF 假设成立。

⇐ 设存在预言机 $\mathcal{O}$ 能以不可忽略的概率 ε 攻破 Rabin 密码体制, 则选择随机消息 m , 计算 $c = m^2 \bmod n$, 询问 $\mathcal{O}(c, n)$, 将会以概率 ε 返回 m' ($1/2$ 的概率有 $m' + m \neq n$)。则有 $\gcd(m' + m, n) = p$ 或 q , 即以不可忽略的概率 $\varepsilon/2$ 分解 n , 与整数分解假设成立相矛盾。



(3) Textbook ElGamal 加密的不安全性

定理 5 ElGamal 系统在 CPA 下满足 All-or-nothing secrecy 当且仅当 CDH 假设 (给定 (g, g^a, g^b) , 计算 $g^{ab} \bmod p$) 成立。

证明:

$\Rightarrow$ 设 CDH 假设不成立, 则给定密文 (c_1, c_2) , 公钥 (p, g, y) , 存在预言机 $\mathcal{O}$ 以不可忽略的概率由 (p, g, y, c_1) 计算出 g^{xk} , 此时可求得 $m = \frac{c_2}{g^{xk}} \bmod p$, 与假设 ElGamal 加密安全相矛盾。

$\Leftarrow$ 设 ElGamal 加密是不安全的, 那么存在预言机 $\mathcal{O}$, 给定公钥 (p, g, y) 和密文 (c_1, c_2) , 以不可忽略概率 ε 获得明文 m 满足

$$\frac{c_2}{m} = g^{\log_g y \log_g c_1} \bmod p.$$

对于 CDH 实例 (p, g, g_1, g_2) , 令 (p, g, g_1) 是公钥, (g_2, c_2) 是密文, 则 $\mathcal{O}$ 以概率 ε 输出 m 满足 $\frac{c_2}{m} = g^{\log_g g_1 \log_g g_2} \bmod p$. 与 CDH 假设成立矛盾。



8.2 公钥加密的安全形式化定义

● 公钥加密体制的敌手模型

- 攻击目标：破译目标密文或密钥。
- 被动攻击：攻击者对密文不操作，也不改变。最主要的是，它不求密钥的拥有者提供某些加解密的服务。
 - 某些部分的信息可能对攻击者有用。
 - 预言机 (Oracle) 的作用。
- 主动攻击：
 - 选择明文攻击 (Chosen-Plaintext Attack, CPA)
 - 选择密文攻击 (Chosen-Ciphertext Attacks, CCA) - 午餐攻击
 - 自适应选择密文攻击 (CCA2) - 晚餐攻击
- 安全模型：
 - 随机预言机模型 (Random Oracle Model)
 - 标准模型 (Standard Model)



● 语义安全

一个安全的加密方案应使敌手通过密文得不到明文的任何部分信息，即使是 1 比特的信息。这就是加密方案**语义安全** (Semantic security) 的概念，由 Goldwasser 和 Micali 于 1984 年提出。

加密方案语义安全的概念由**不可区分性** (Indistinguishability) **游戏** (简称 IND 游戏) 来刻画，这种游戏是一种思维实验，其中有 2 个参与者，一个称为**挑战者** (Challenger)，另一个是敌手 (Adversary)。挑战者建立系统，敌手对系统发起挑战，挑战者接受敌手的挑战。

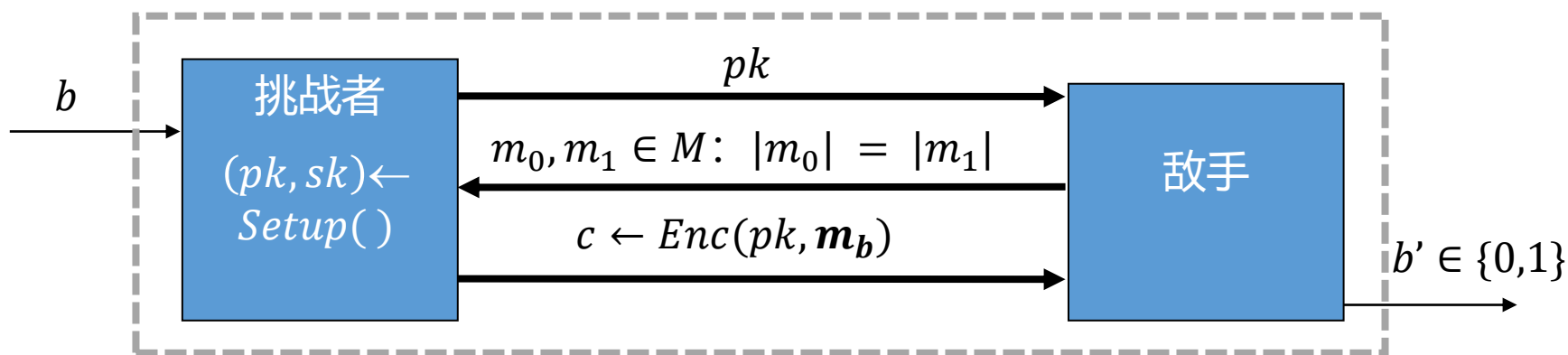
语义安全这一概念的提出开创了**可证明安全性**领域的先河。

[8] S. Goldwasser, S. Micali. Probabilistic encryption. Journal of Computer and System Sciences, 28: 270-299, 1984.



(1) 选择明文攻击下的不可区分性 (IND-CPA 安全性)

对于 $b = \{0,1\}$, 定义实验 $EXP(b)$ 为:



公钥加密方案 $PKE = (Setup, Enc, Dec)$ 是 IND-CPA 安全的, 如果对于任意的敌手 $\mathcal{A}$ 有:

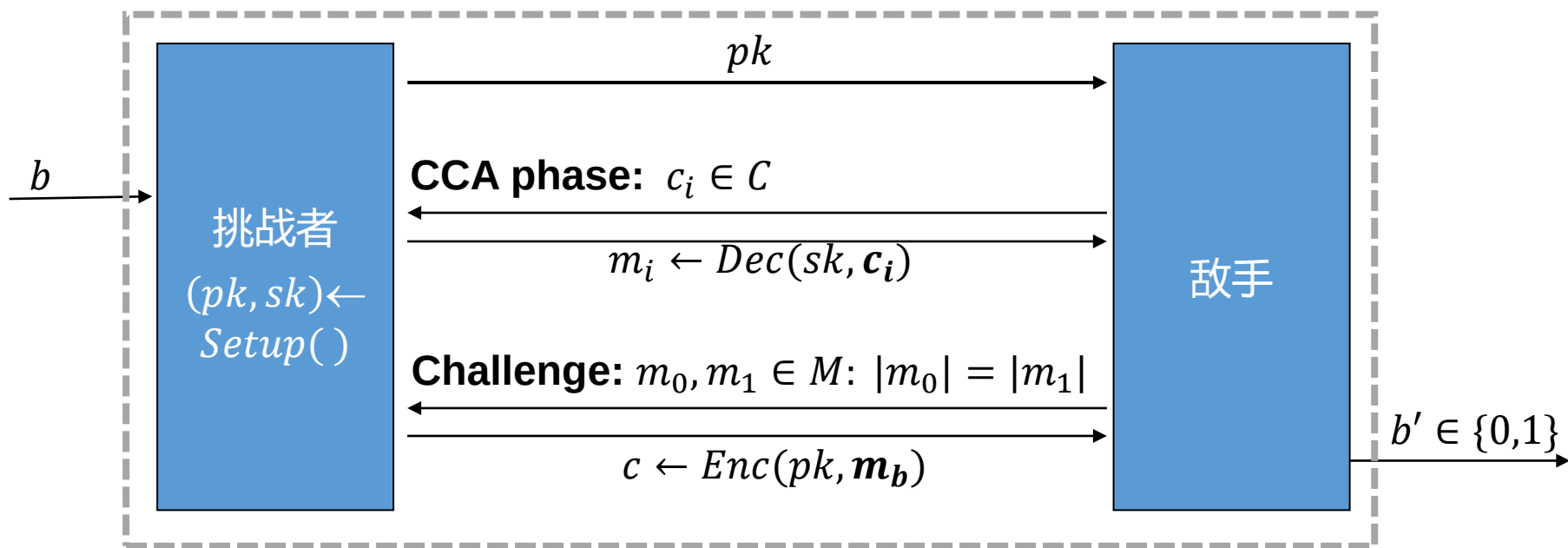
$$Adv_{CPA}[\mathcal{A}, PKE] = |\Pr[EXP(0) = 1] - \Pr[EXP(1) = 1]| < negligible$$

不可区分性与语义安全性在 CPA 攻击下是等价概念。



(2) 选择密文攻击下的不可区分性 (IND-CCA 安全性)

为了进一步增强安全性，该模型额外地允许攻击者获得解密模式下的有条件帮助。对 IND-CCA模型的形式化处理基于 Naor 和 Yung 给出的游戏。该游戏称为“午餐攻击”或“冷漠选择密文攻击”。

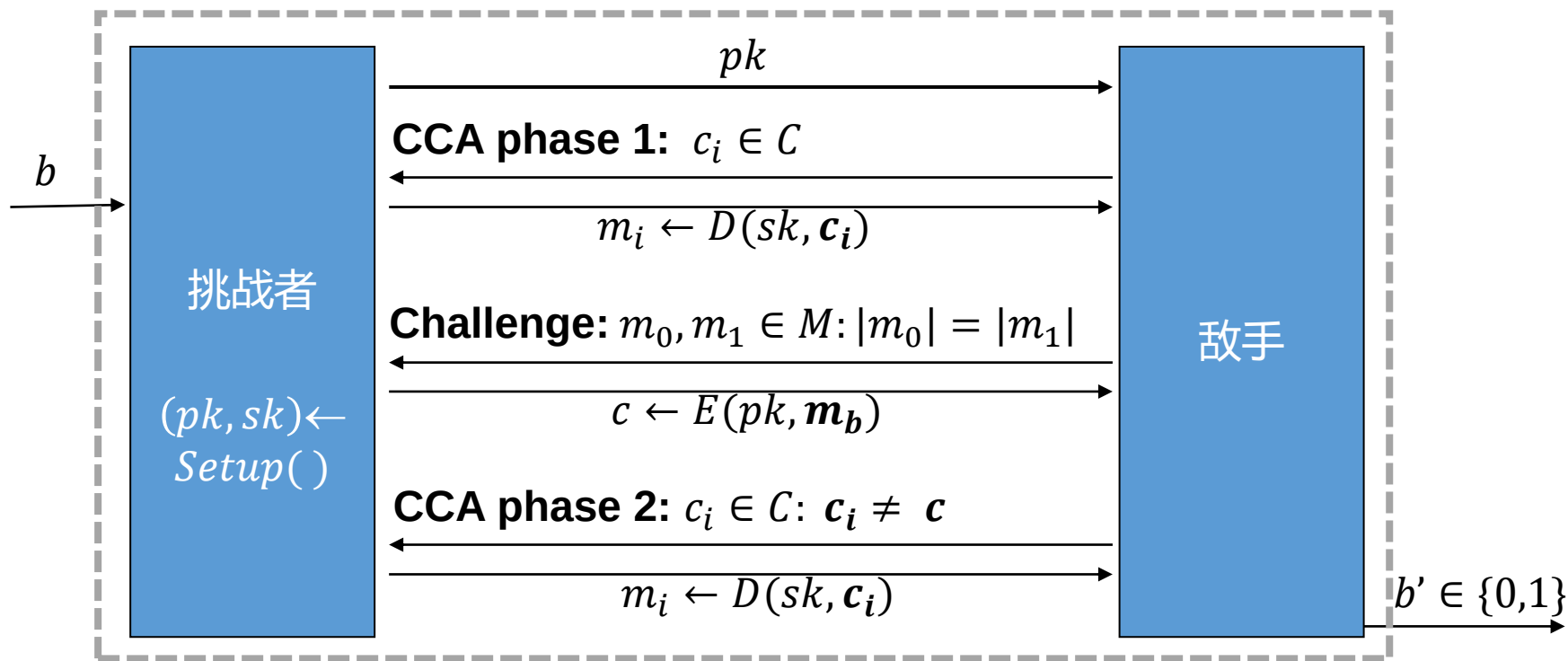


[9] M. Naor, M. Yung. Public-key cryptosystems provably secure against chosen ciphertext attacks. Proceedings of 22nd ACM Symposium of Theory of Computing, 427-437, 1990.



(3) 适应性选择密文攻击下的不可区分性 (IND-CCA2 安全性)

Rackoff 和 Simon 于 1991 年提出了这种更强的攻击模型，该模型去掉了只能在短时间内得到解密帮助这个不合理的假设。



[10] C. Rackoff, D. Simon. Non-interactive zero-knowledge proof of knowledge and chosen ciphertext attack. Proceedings of CRYPTO 1991, 433-444, 1991.



CPA 安全性是公钥加密方案的一个基本安全性要求，公钥加密方案往往需要满足更高级的安全性要求，以提供更强的安全性保证。然而，构造 CPA 安全的公钥加密方案是足够的，因为目前已存在 CPA 安全方案到 CCA2 安全方案的转化方法。

基于IND-CPA 方案可以构造出 IND-CCA2 方案：

- CPA + One time NIZK [11] $\Rightarrow$ CCA2
- CPA + Plaintext Awareness $\Rightarrow$ CCA2
- CPA + Fujii-Okamoto method [12] $\Rightarrow$ CCA2

[11] M. Naor, M. Yung. Public-key cryptosystems provably secure against chosen ciphertext attacks. Proceedings of STOC 1990, 427-437. 1990.

[12] E. Fujisaki and T. Okamoto. How to enhance the security of public key encryption at minimum cost. Proceedings of PKC 1999, 53-68. 1999.



不可延展 (Non-malleable) 密码学从计算方面加强公钥密码体制的安全性定义。它使得攻击者不易以一种有意义的可控方式通过修改密文而修改相应的明文。与不可区分性的各种攻击情况（它们的攻击问题是判定问题）不同，可延展性攻击的是一个计算问题。

不可区分性和不可延展性之间的关系：

➤ 不可延展性蕴含不可区分性

假设 ATK 表示 CPA、CCA 或 CCA2，如果一个公钥密码体制是 NM- ATK 安全的，那么它一定是 IND- ATK 安全的。

➤ 在 CCA2 攻击下，不可区分性和不可延展性是等价的

公钥密码体制是 NM-CCA2 安全的当且仅当它是 IND-CCA2 安全的。

[13] D. Dolev, C. Dwork, and M. Naor. Non-malleable cryptography. Proceedings of 23rd Annual ACM Symposium on Theory of Computing, 542-552, 1991.



9.1 私钥加密和公钥加密的对比

	私钥加密	公钥加密
运行条件	➤ 加密和解密使用同一个密钥和算法。 ➤ 发送方和接收方必须共享密钥和算法。	➤ 用不同的算法和密钥进行加密和解密 ➤ 无需密钥协商，接收方只需保管好私钥。
安全条件	➤ 密钥必须保密。 ➤ 如果不掌握其他信息，要想解密密文是不可能或者至少是不现实的。 ➤ 知道所用的算法和密文的样本必须不足以确定密钥。	➤ 私钥必须保密。 ➤ 如果不掌握其他信息，要想解密密文是不可能或者至少是计算上不可行的。 ➤ 知道所用的算法、公钥以及密文必须不足以确定私钥。
运行速度	运算速度快，适合加密大量数据。	运算速度慢，适合加密少量数据。



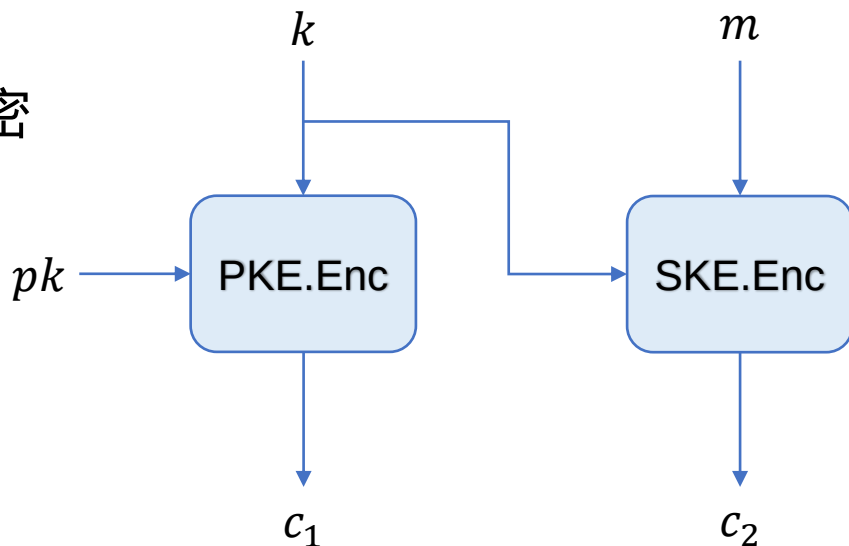
9.2 私钥加密和公钥加密的组合——Hybrid 加密

Hybrid 加密结合了私钥加密和公钥加密两种不同的加密方法，以充分利用它们各自的优点去保护数据的机密性和完整性。公钥加密相对于私钥加密来说速度慢，效率低。所以公钥加密体制可用来加密临时的会话密钥，然后使用此密钥作为私钥加密体制的种子密钥去加密消息。

例如：数字信封 = RSA 加密 + AES 加密

数字信封存在两个缺点：

1. 产生并分发密钥者主动
2. 不具备前向安全性





- ❑ 设计公钥加密体制的关键是先要寻求一个合适的陷门单向函数。
- ❑ 背包密码体制是第一个公开发表的基于“困难问题”的公钥密码体制。
- ❑ 教科书式 RSA 加密、Rabin 加密和 ElGamal 加密方案，其安全性均为完全或无保密，仅能抵抗被动攻击者。
- ❑ Paillier 加密是一个支持加法同态的公钥密码系统。
- ❑ 公钥加密体制的安全性由弱到强分别为：完全或无安全性、语义安全性（IND-CPA）、IND-CCA、IND-CCA2。
- ❑ 不可延展性从计算方面加强公钥密码体制的安全性定义。在 CCA2 攻击下，不可区分性和不可延展性是等价的。



西安电子科技大学
XIDIAN UNIVERSITY

西安电子科技大学

团结 勤奋

求实 创新

谢谢！

THANK YOU

全心全意为人
民服务
毛泽东